
AI-Powered GitHub Repository Secret Leakage Detector

14th November 2025

Introduction

With the rapid growth of modern software development, GitHub has become the world's largest code hosting platform. However, it is also one of the most common sources of accidental credential leakage, where developers unknowingly push sensitive information such as API keys, authentication tokens, database credentials, cloud access secrets, and configuration files.

Such leaks have resulted in major real-world security incidents, including breaches at Uber, Toyota, Samsung, and Twitch. Attackers continuously scrape public repositories for exposed secrets, often exploiting them within minutes.

This project proposes the development of an AI-powered Secret Leakage Detection System. The system will automatically scan GitHub repositories for potential leaked credentials using a combination of regex pattern matching, entropy-based statistical analysis, and machine learning classification.

Users can simply provide a GitHub URL or upload a repository, and the web app—built on Next.js—will analyze the files and produce a detailed security report.

Project Goals

The primary goals of the project are:

1. **Detect leaked credentials automatically** inside GitHub repositories, including:
 - API keys (AWS, Google Cloud, Stripe, GitHub, etc.)
 - Access tokens
 - OAuth/SSH keys
 - Hardcoded database passwords
 - JWTs and session secrets
 - `.env` and configuration files
2. **Develop a hybrid detection engine** combining:
 - **Regex-based detection** for known patterns
 - **Shannon entropy analysis** for high-randomness strings

-
- **Machine Learning classifier** to distinguish real secrets from false positives
3. **Provide a user-friendly Next.js web interface** where users can:
 - Enter a GitHub URL or upload a zip file
 - View a categorized list of detected secrets
 - View severity and ML confidence scores
 - Download a security report with remediation suggestions
 4. Build the system as a **prototype security product**, demonstrating:
 - Web security automation
 - Real-time analysis
 - API-driven architecture
 - Practical DevSecOps application

Scope of the Project

The project will include the following components:

3.1 Frontend Web Application (Next.js)

- Clean and modern dashboard interface
- Input fields for GitHub repository URL or file upload
- Display of results using tables, severity indicators, and code snippets
- Downloadable PDF/JSON security report

3.2 Backend Scanning Engine

- Cloning or unpacking repository files
- File walker to traverse all code files
- Secret detection modules:
 - Regex scanning of known credential formats
 - Entropy scoring to flag high-randomness sequences
 - ML classifier predicting whether a candidate string is likely a secret

3.3 Machine Learning Component

- Custom dataset of “secret” vs “non-secret” strings
- Training a lightweight ML model (e.g., Logistic Regression, Random Forest)
- Generating a **final risk score** using ML + entropy + regex signals

3.4 Reporting and Visualization

- Categorized results (High/Medium/Low severity)

-
- Identification of file paths, line numbers, and secret types
 - Risk scoring and ML confidence
 - Explanation of why each item was flagged
 - Summary of recommended security fixes

Importance and Real-World Applications

This project addresses a critical real-world security problem:

- Secret leakage is one of the top causes of breaches, leading to unauthorized access to cloud services, databases, financial services, and production systems.
- Developers often accidentally include secrets in commits due to convenience or oversight.
- Existing tools (GitGuardian, Trivy, Gitleaks) are widely used in industry—showing a clear need for such solutions—but many lack:
 - ML-driven intelligence
 - Custom dashboards
 - Flexible SaaS hosting

Applications

1. **DevSecOps pipelines** – automated scanning during CI/CD.
2. **Enterprise GitHub monitoring** – protecting large codebases.
3. **Student and academic projects** – preventing accidental key exposure.
4. **Open-source maintainers** – ensuring safe contributions.
5. **Security teams** – detecting risks before attackers do.

By building a system combining AI + security + automation, this project demonstrates a modern approach to preventing real-world cyberattacks.

Conclusion

The AI-Powered GitHub Repository Secret Leakage Detector presents a practical, innovative, and highly relevant solution to one of today's most critical software security challenges. By integrating rule-based scanning, entropy analysis, and machine-learning-driven detection, the system offers a more intelligent and adaptive approach than traditional static tools. The inclusion of a modern Next.js web interface transforms the scanner into a usable, accessible, and scalable SaaS-style platform. This project not only demonstrates the application of AI in cybersecurity but also showcases real-world impact—protecting developers, organizations, and open-source ecosystems from costly breaches due to credential leakage. As a complete end-to-end solution, it

reflects strong engineering, practical DevSecOps thinking, and the ability to build security products that address real threats faced in the software industry today.